Luiss
Libera Università Internazionale
degli Studi Sociali Guido Carli

Web Vulnerabilities: SSTI and Access Control Bypass

Data Privacy and Security

Data Science and Management (DASMA)

LUISS

TheWebHackTimes

Web Challenge 24

TheWebHackTimes - Reconnaissance

WebHackIT is proud to announce TheWebHackTimes!

This is a new online newspaper. A subset of the content is accessibile only to paying readers.

However, an interal source says that there is an easy way to bypass the restriction and this was due to SEO craziness...

SEO

What it is: Optimizing a website to rank higher on search engines

SEO

What it is: Optimizing a website to rank higher on search engines

Why it matters: More visibility → more traffic → more results

How does SEO works?

1. Crawling – Search engines scan your website
2. Indexing – Pages are stored in their database
3. Ranking – Content is ranked based on relevance & quality

What influences ranking:

- Keywords (match search intent)
- Content quality
- Website speed & mobile-friendliness
- Backlinks (trust signals)

TheWebHackTimes - Reconnaissance pt.2

What can we observe? The challenge resents a page that shows a newspaper with some areas grayed-out.

Those areas are meant for paying users and not regular users.

TheWebHackTimes - Reconnaissance pt.2

What can we observe? The challenge resents a page that shows a newspaper with some areas grayed-out.

Those areas are meant for paying users and not regular users.

> How to obtain access to the whole newspaper without paying?

SEO and Web Spiders

How the search engine crawls the pages? With spiders: Automated bots (crawlers) used by search engines to scan and index webpages

SEO and Web Spiders

How the search engine crawls the pages? With spiders: Automated bots (crawlers) used by search engines to scan and index webpages

How sites treat them:

- Identified via **user agent**
- Often allowed full access to content for better indexing (SEO): This ensures full content appears in search results

SEO and Web Spiders

How the search engine crawls the pages? With spiders: Automated bots (crawlers) used by search engines to scan and index webpages

How sites treat them:

- Identified via **user agent**
- Often allowed full access to content for better indexing (SEO): This ensures full content appears in search results

Important note:

- This access is intended for search engines, not users
- Bypassing paywalls manually may violate site terms

TheWebHackTimes - Hypothesis

MAYBE we can bypass the paywall changing the user-agent to the one of a web crawler

TheWebHackTimes - Hypothesis

MAYBE we can bypass the paywall changing the user-agent to the one of a web crawler

> Modern browser allow the user to do it without additional plugins or extensions :)

SuperSecretEncrypter

Web Challenge 28

SuperSecretEncrypter - Reconnaissance

What can we observe?

SuperSecretEncrypter - Reconnaissance

What can we observe?

> **NOTE**: the flag is located at ./flag.txt

SuperSecretEncrypter - Reconnaissance

What can we observe?

> **NOTE**: the flag is located at ./flag.txt

This means we need to access the filesystem of the web server to retreive the flag

SuperSecretEncrypter - Reconnaissance pt.2

Are there ways to execute arbitrary user-provided code?

SuperSecretEncrypter - Reconnaissance pt.2

Are there ways to execute arbitrary user-provided code?

> Apparently NO! But maybe...

SuperSecretEncrypter - Reconnaissance pt.2

Are there ways to execute arbitrary user-provided code?

> Apparently NO! But maybe...

Can you understand how the backend was made?

SuperSecretEncrypter - Reconnaissance pt.2

Are there ways to execute arbitrary user-provided code?

> Apparently NO! But maybe...

Can you understand how the backend was made?

The backend language?

SuperSecretEncrypter - Reconnaissance pt.2

Are there ways to execute arbitrary user-provided code?

> Apparently NO! But maybe...

Can you understand how the backend was made?

The backend language?

The backend framework?

SuperSecretEncrypter - Reconnaissance pt.3

From the source code you can find:

```
        <div style="margin: 10%; width: 33%; max-width: 25%; word-wrap: break-word">
            <!-- jinja2 is so powerful! -->
            <h5>Your Plaintext:</h5><br>
```

SuperSecretEncrypter - Reconnaissance pt.3

From the source code you can find:

```
        <div style="margin: 10%; width: 33%; max-width: 25%; word-wrap: break-word">
            <!-- jinja2 is so powerful! -->
            <h5>Your Plaintext:</h5><br>
```

> What is Jinja2?

Jinja2

A Python templating engine used to generate dynamic HTML

Jinja2

A Python templating engine used to generate dynamic HTML

How it works:

- Combines templates + data → final web page
- Uses placeholders and log

Jinja2

A Python templating engine used to generate dynamic HTML

How it works:

- Combines templates + data → final web page
- Uses placeholders and log

Key features:

- Variables: `{{ name }}`
- Control flow: `{% if %}`, `{% for %}`
- Template inheritance (base layouts)

Jinja2

A Python templating engine used to generate dynamic HTML

How it works:

- Combines templates + data → final web page
- Uses placeholders and log

Key features:

- Variables: `{{ name }}`
- Control flow: `{% if %}`, `{% for %}`
- Template inheritance (base layouts)

> Is it vulnerable to code injection?

Try to hack Jinja2

To check if Jinja2 is vulnerable to template injection, try to encrypt and decrypt some code

```
{{ 30 + 12 }}
```

Try to hack Jinja2

To check if Jinja2 is vulnerable to template injection, try to encrypt and decrypt some code

```
{{ 30 + 12 }}
```

> If the output is 42 this means that we successfully injected some code into the template

Try to hack Jinja2

To check if Jinja2 is vulnerable to template injection, try to encrypt and decrypt some code

```
{{ 30 + 12 }}
```

If the output is 42 this means that we successfully injected some code into the template

Now look online for an exploit to either execute `cat flag.txt` or read the content of the file `flag.txt`